Entrega 6 — Data Security: Minha Rota

A. Identificação dos Dados

No projeto Minha Rota, os dados são classificados da seguinte forma:

- **Dados Públicos:** Informações gerais da própria plataforma (missão, visão, contatos comerciais da transportadora no site institucional).
- **Dados Internos:** Número de frotas ativas, capacidade dos veículos, horários de saída das garagens e métricas do Data Warehouse (taxas de ocupação e custos operacionais).
- **Dados Confidenciais:** Contratos com as empresas parceiras (B2B), CNPJ das contratantes, valores de faturamento, senhas e credenciais de infraestrutura (chaves de API do Mapas).
- **Dados Sensíveis (LGPD):** Nome completo dos colaboradores (passageiros), endereço residencial exato, geolocalização (latitude/longitude), turno de trabalho e o vínculo empregatício com a empresa contratante.

B. Controle de Acesso

O acesso será rigorosamente controlado pelo **Princípio do Menor Privilégio (Least Privilege)**, impedindo que um usuário veja dados fora do seu escopo através da validação do seu Role e ID no Backend.

- **Administrador (Equipe Minha Rota):** Acesso completo ao sistema e gestão de usuários, mas sem acesso direto ao banco de dados em produção (este é restrito a DBAs autenticados via VPN).
- **RH da Empresa Contratante (Cliente B2B):** Acesso restrito aos dados da sua própria empresa. Pode gerir apenas os seus próprios colaboradores e rotas contratadas. (*Ex: O RH da Empresa A nunca vê os dados da Empresa B*).
- **Motorista:** Acesso extremamente restrito. Visualiza apenas as viagens atribuídas a ele no dia específico, e apenas o nome do passageiro e o ponto de apanha correspondente. Não visualiza endereços residenciais ou empresas de passageiros de outras rotas.
- **Colaborador (Passageiro):** Acesso somente às suas próprias informações. Visualiza apenas o nome do seu motorista diário, a placa do veículo e a sua rota.

C. Autenticação e Autorização

- **Autenticação:** Os usuários serão autenticados através de e-mail e senha. A validação devolverá um **Token JWT (JSON Web Token)**.
- **Autorização:** Será feita baseada em funções (**RBAC - Role-Based Access Control**). O Payload do JWT conterá o role do usuário (ADMIN, RH, MOTORISTA, PASSAGEIRO) e o id_empresa. Em cada requisição, a API do backend (Express/Spring Boot) verificará este token.
- **Tratamento de Tentativas Não Autorizadas:** Se a API identificar uma falha na assinatura do token, uma expiração, ou se um MOTORISTA tentar aceder a um Endpoint de ADMIN, o sistema devolverá imediatamente um erro **HTTP 401 (Unauthorized)** ou **403 (Forbidden)**. Múltiplas tentativas falhadas de login resultarão num bloqueio temporário da conta (Rate Limiting).

D. Proteção dos Dados

- **Durante a transmissão:** Todos os dados em trânsito entre a Web/App e a API serão criptografados através do protocolo **HTTPS/TLS 1.2+**. Nenhuma requisição HTTP será permitida (redirecionamento obrigatório).
- **Durante o armazenamento:**
    - Os discos onde os bancos de dados estão alocados na Nuvem estarão criptografados em repouso (Encryption at Rest) utilizando chaves AES-256.
    - As senhas de usuários **nunca** serão armazenadas em texto limpo; utilizarão o algoritmo **Bcrypt** com Salt dinâmico.
- **Durante o processamento:**
    - O servidor da API e o servidor de banco de dados não terão IP público; estarão isolados dentro de uma VPC (Virtual Private Cloud) privada.
    - As credenciais de conexão com o banco (Login/Senha) e chaves da API de Mapas estarão protegidas através de Variáveis de Ambiente (.env) geridas por um serviço de Secrets Management, nunca hardcoded no código-fonte.

E. Auditoria

Com base na necessidade crítica de conformidade com a LGPD e o sistema B2B, as seguintes operações serão obrigatoriamente registradas (Log de Auditoria):

- **Login:** Sucesso e falha (identificando IP e dispositivo) para detetar força bruta.
- **Visualização de Dados Sensíveis:** Sempre que um RH ou Administrador puxar um relatório com moradas e nomes de colaboradores.
- **Alteração de Dados Pessoais:** Modificação de turnos, locais de apanha ou status do colaborador.
- **Exclusão ou Anonimização:** Registo de quem autorizou a exclusão/soft-delete de um colaborador desligado.
- **Alteração de Permissões:** Quando a função (Role) de um usuário for alterada (ex: um RH ganha privilégios de Admin).

F. Riscos

Risco	Impacto	Estratégia de proteção
Vazamento do banco de dados em repouso (acesso não autorizado aos discos da Cloud)	Alto	Utilização de **Criptografia em Repouso (AES-256)**. Mesmo que o disco seja roubado ou copiado, os ficheiros estarão ilegíveis sem a chave do provedor.
Interceptação dos dados (Ataque Man-in-the-Middle) entre o celular do motorista e o servidor	Alto	Implementação estrita de **HTTPS/TLS** nos aplicativos. Os dados são encriptados antes de saírem do dispositivo, tornando-os inúteis se interceptados na rede.

Vazamento de credenciais via código-fonte (Desenvolvedor colocar a senha do banco no GitHub)	Alto	Uso de **Variáveis de Ambiente e Serviços de Gestão de Secrets**. O código pede a variável, e a senha nunca é enviada para o repositório.
Acesso Indevido (Excesso de Privilégio) onde um motorista vê a lista completa de todos os passageiros da transportadora	Alto	Implementação de **Controlo de Autorização Baseado em Roles (RBAC)** no backend e verificação de dono do dado (validar se id_motorista na Viagem bate com o token) nas regras de negócio.
Roubo do banco de dados expondo as senhas de todos os usuários	Crítico	Utilização de algoritmo de **Hash irreversível (Bcrypt)** com Salt. Se o banco for invadido, o atacante apenas verá hashes encriptados e será incapaz de descobrir as senhas reais.